

VULNERABILITY ASSESSMENT REPORT

Web Application Security Review

Prepared by: Abinash Reddy

Internship: Future Interns – Cyber Security Track

Task: Task 1 – Vulnerability Assessment Report for a Live Website

Date: July 2026

1. Executive Summary

This report presents the findings of a passive, read-only vulnerability assessment conducted on a permitted public test domain, zero.webappsecurity.com (a demo banking application provided for security testing practice), along with a network-level scan of scanme.nmap.org (Nmap's official permitted scanning target).

The assessment used industry-standard tools — Nmap, OWASP ZAP, and browser developer tools — to identify configuration weaknesses, missing security controls, and outdated components. A total of 8 distinct findings were identified, ranging from Medium to Low risk. No high-risk or critical vulnerabilities were found; however, several issues represent meaningful gaps in the application's defense-in-depth posture that should be addressed to reduce exposure to common web attacks such as Cross-Site Scripting (XSS), Clickjacking, and Cross-Site Request Forgery (CSRF).

2. Scope

Target (Web)	http://zero.webappsecurity.com
Target (Network)	scanme.nmap.org
Testing Type	Passive / Read-only (no exploitation, no login bypass, no active attack payloads)
Authorization	Both targets are publicly designated for security testing practice
Testing Period	July 2026
Tools Used	Nmap, OWASP ZAP (passive scan), Browser DevTools

Out of scope: Active exploitation, brute-force login attempts, denial-of-service testing, and any action beyond passive observation and read-only analysis.

3. Methodology

1. Network Reconnaissance – Nmap service/version scan to identify open ports and running software versions.
2. Passive Web Application Scan – OWASP ZAP was used in Manual Explore mode to browse the target site while passively recording and analyzing every request and response. No active/attack scanning was performed.
3. Manual Header & Cookie Review – Browser DevTools (Network and Application tabs) were used to independently verify HTTP response headers and cookie security attributes.

All findings below were cross-validated across at least two of the three methods where applicable.

4. Findings Summary

#	Finding	Risk	CWE
1	Outdated JavaScript Library (jQuery 1.6.4, 1.7.2, 1.8.2)	Medium	CWE-1395
2	Missing Content Security Policy (CSP) Header	Medium	CWE-693
3	Missing Anti-Clickjacking Header (X-Frame-Options)	Medium	CWE-1021
4	Absence of Anti-CSRF Tokens	Medium	CWE-352
5	Server Version Disclosure	Low	CWE-497

6	Session Cookie Missing Secure & SameSite Attributes	Low	CWE-1275
7	Missing X-Content-Type-Options Header	Low	CWE-693
8	Unencrypted Transport (Site served over HTTP, not HTTPS)	Medium	CWE-319

Additional network-level observation: Nmap identified outdated service versions (OpenSSH 6.6.1, Apache 2.4.7) on the scanme.nmap.org host, indicating unpatched, end-of-life software — included as a supplementary network-layer example, not tied to the primary web target.

5. Detailed Findings

5.1 Outdated JavaScript Library — Medium Risk

Description: The application loads three outdated versions of the jQuery library (1.6.4, 1.7.2, 1.8.2). Version 1.6.4 is affected by publicly documented vulnerabilities CVE-2020-11023 and CVE-2015-9251, both related to Cross-Site Scripting (XSS).

Business Impact: Attackers can use publicly available exploit code targeting these known flaws, potentially allowing malicious script execution in users' browsers, session theft, or defacement.

Remediation: Upgrade all jQuery references to the latest stable release (3.x or later) and establish a periodic dependency audit process.

CWE Reference: CWE-1395



Figure 5.1 — ZAP passive scan detail: Vulnerable JS Library

5.2 Missing Content Security Policy (CSP) Header — Medium Risk

Description: The application does not send a Content-Security-Policy header,

which normally restricts which sources of scripts, styles, and other content the browser is allowed to load.

Business Impact: Without CSP, the application has no additional browser-enforced defense against XSS or malicious content injection, beyond input sanitization alone.

Remediation: Configure the web/application server to send an appropriate CSP header restricting content sources to trusted origins.

CWE Reference: CWE-693



Figure 5.2 — ZAP passive scan detail: CSP Header Not Set

5.3 Missing Anti-Clickjacking Header — Medium Risk

Description: The application does not send an X-Frame-Options header or CSP frame-ancestors directive.

Business Impact: The site could be embedded within a malicious page using an invisible iframe, tricking users into unintentionally clicking real page elements (Clickjacking).

Remediation: Add X-Frame-Options: SAMEORIGIN (or DENY) to all server responses.

CWE Reference: CWE-1021



Figure 5.3 — ZAP passive scan detail: Missing Anti-Clickjacking Header

5.4 Absence of Anti-CSRF Tokens — Medium Risk

Description: The feedback submission form does not include an anti-CSRF token.

Business Impact: An attacker could craft a malicious page that silently submits requests on behalf of an authenticated user without their knowledge or consent.

Remediation: Implement anti-CSRF tokens using a vetted framework/library (e.g., OWASP CSRFGuard) on all state-changing forms.

CWE Reference: CWE-352



Figure 5.4 — ZAP passive scan detail: Absence of Anti-CSRF Tokens

5.5 Server Version Disclosure — Low Risk

Description: The Server HTTP response header discloses the exact software and version in use (Apache-Coyote/1.1).

Business Impact: Reveals technical details that help attackers identify and target known vulnerabilities specific to that software version.

Remediation: Configure the server to suppress or generalize the Server header.

CWE Reference: CWE-497



Figure 5.5 — ZAP passive scan detail: Server Leaks Version Information

5.6 Session Cookie Missing Secure & SameSite Attributes — Low Risk

Description: The JSESSIONID session cookie is set without the Secure or SameSite attributes, confirmed via both ZAP and browser DevTools inspection.

Business Impact: The cookie can be transmitted over unencrypted connections and may be sent as part of cross-site requests, increasing exposure to session hijacking and CSRF-style attacks.

Remediation: Set Secure and SameSite=Lax (or Strict) attributes on all session cookies.

CWE Reference: CWE-1275



Figure 5.7 — ZAP passive scan detail: X-Content-Type-Options Header Missing

5.8 Unencrypted Transport (HTTP instead of HTTPS) — Medium Risk

Description: The application is served entirely over plain HTTP rather than HTTPS, including pages that would normally handle sensitive banking-style data in a production context.

Business Impact: All traffic, including session cookies and any submitted form data, is transmitted in plaintext and can be intercepted by anyone on the same network path.

Remediation: Enforce HTTPS across the entire application using a valid TLS certificate, and redirect all HTTP traffic to HTTPS.

CWE Reference: CWE-319

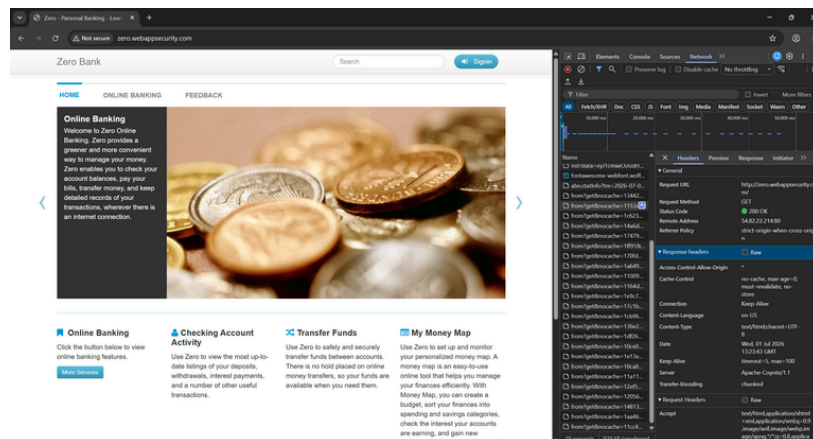


Figure 5.8 — Browser DevTools: Response headers confirming HTTP transport and server disclosure

Appendix A — Network Scan Evidence

Nmap service/version scan performed against scanme.nmap.org (permitted test target):

```
abina@Ablinash MINGW64 ~/FUTURE_CS_01 (main)
$ nmap -sV -F scanme.nmap.org > scan-output/nmap_output.txt
cat scan-output/nmap_output.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 15:31 +0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.25s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 97 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
25/tcp    filtered  smtp
80/tcp    open      http         Apache httpd 2.4.7 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.82 seconds

abina@Ablinash MINGW64 ~/FUTURE_CS_01 (main)
$ |
```

Figure A.1 — Nmap scan results: open ports and service versions

Appendix B — ZAP Alert Summary

Overview of all passive scan alerts identified by OWASP ZAP:

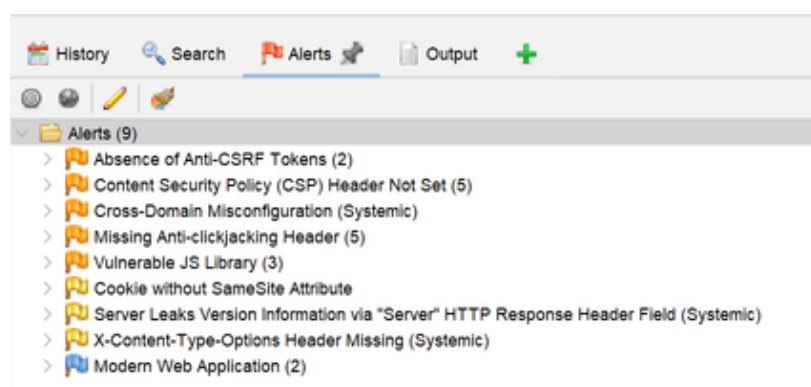


Figure B.1 — OWASP ZAP Alerts panel overview (9 alert categories)

6. Risk Rating Summary

- Medium Risk: 5 findings
- Low Risk: 3 findings
- High/Critical Risk: 0 findings

7. Conclusion

While no high-severity vulnerabilities were identified during this passive assessment, the target application shows a consistent pattern of missing browser-enforced security headers and outdated components. These are common, well-understood issues with straightforward remediation paths, and addressing them would meaningfully improve the application's baseline security posture and its resilience against common attack classes such as XSS, Clickjacking, and CSRF.

8. Tools & References

- Nmap – <https://nmap.org>
- OWASP ZAP – <https://www.zaproxy.org>
- OWASP Top 10 (2021) – <https://owasp.org/Top10/>
- Browser DevTools (Chrome)

This assessment was conducted strictly within a passive, read-only scope against publicly authorized test domains, as part of the Future Interns Cyber Security internship program (Task 1).